

Cyber threat: An internal or external circumstance, event, action, occurrence, or person with the potential to exploit technology-based vulnerabilities and to adversely affect (create adverse consequences for) organizational operations, organizational assets (including information and information systems), individuals, other organizations, or society.

Cybersecurity: The process of protecting consumer and bank information by preventing, detecting, and responding to attacks.

Data classification program: A program that categorizes data to convey required safeguards for information confidentiality, integrity, and availability, and establishes required controls based on value and level of sensitivity.

Data corruption: Errors in computer data that occur during writing, reading, storage, transmission, or processing, which introduce unintended changes to the original data.

Data integrity: The property that data have not been destroyed or corrupted in an unauthorized manner; maintaining and assuring the accuracy and consistency of data over their entire life cycle.

Data loss prevention (DLP) program: A comprehensive approach (covering people, processes, and systems) of implementing policies and controls designed specifically to discover, monitor, and protect confidential data while it is stored, used, or in transit over the network and at the perimeter.

Database: A collection of data that is stored on any type of computer storage medium and may be used for more than one purpose.

Defense-in-depth: Information security strategy integrating people, technology, and operations capabilities to establish variable barriers across multiple layers and dimensions of the organization.

Demilitarized zone (DMZ): A computer or small subnetwork that sits between a trusted internal network, such as a corporate private LAN, and an untrusted external network, such as the public Internet.

Detection device: A device designed to recognize an event and alert management when events occur.

Detective control: A mitigating technique designed to recognize an event and alert management when events occur.

Device: A generic term for any machine or component that attaches to a computer or connects to a network.

Distributed denial of service (DDoS): A type of attack that makes a computer resource or resources unavailable to its intended users. Although the means to carry out, motives for, and

targets of a DDoS attack may vary, it generally consists of the concerted efforts of a group that intends to affect an institution's reputation by preventing an Internet site, service, or application from functioning efficiently.

Due diligence for service provider selection: Technical, functional, and financial review to verify a third-party service provider's ability to deliver the requirements specified in its proposal. The intent is to verify that the service provider has a well-developed plan and adequate resources and experience to ensure acceptable service, controls, systems backup, availability, and continuity of service to its clients.

End-of-life: All software products have life cycles. End-of-life refers to the date when a software development company no longer provides automatic fixes, updates, or online technical assistance for the product.

End-point security: Refers to a methodology of protecting the corporate network when accessed with remote devices, such as laptops, or other wireless and mobile devices. Each device with a remote connection to the network creates a potential entry (or exit) point for security threats.

End-to-end process flow: Document that details the flow of the processes, considering automated and manual control points, hardware, databases, network protocols, and real-time versus periodic processing characteristics.

Enterprise-wide: Across an entire organization, rather than a single business department or function.

Exploit: A technique or code that uses a vulnerability to provide system access to the attacker. An exploit is an intentional attack to affect an operating system or application program.

External connections: An information system or component of an information system that is outside of the authorization boundary established by the organization and for which the organization typically has no direct control over the application of required security controls or the assessment of security control effectiveness.

File transfer protocol (FTP): A standard high-level protocol for transferring files from one computer to another, usually implemented as an application-level program.

Financial Services Information Sharing and Analysis Center (FS-ISAC): A nonprofit, information-sharing forum established by financial services industry participants to facilitate the public and private sectors' sharing of physical and cybersecurity threat and vulnerability information.

Firewall: A hardware or software link in a network that relays only data packets clearly intended and authorized to reach the other side.

Frame relay: A high-performance wide area network protocol that operates at the physical and data link layers of the Open Systems Interconnection reference model. Frame relay is an example

of a packet-switched technology. Packet-switched networks enable end stations to dynamically share the network medium and the available bandwidth.

Governance: In computer security, governance means setting clear expectations for the conduct (behaviors and actions) of the entity being governed and directing, controlling, and strongly influencing the entity to achieve these expectations. Governance includes specifying a framework for decision making, with assigned decision rights and accountability, intended to consistently produce desired behaviors and actions.

Gramm–Leach–Bliley Act: The act, also known as the Financial Services Modernization Act of 1999 (Pub.L. 106-102, 113 Stat. 1338, enacted November 12, 1999), required the federal banking agencies to establish information security standards for financial institutions.

Hardening: The process of securing a computer’s administrative functions or inactivating those features not needed for the computer’s intended business purpose.

Hardware: The physical elements of a computer system; the computer equipment as opposed to the programs or information stored in a machine.

Hash: A fixed-length cryptographic output of variables, such as a message, being operated on by a formula or cryptographic algorithm.

Hijacking: An attacker’s use of an authenticated user’s communication session to communicate with system components.

Homing beacons: Devices that send messages to the institution when they connect to a network and that enable recovery of the device.

Host: A computer that is accessed by a user from a remote location.

Incident management: The process of identifying, analyzing, and correcting disruptions to operations and preventing future recurrences. The goal of incident management is to limit the disruption and restore operations as quickly as possible.

Incident response plan: A plan that defines the action steps, involved resources, and communication strategy upon identification of a threat or potential threat event, such as a breach in security protocol, power or telecommunications outage, severe weather, or workplace violence.

Information security: The process by which an organization protects the creation, collection, storage, use, transmission, and disposal of information.

Information systems: Electronic systems and physical components used to access, store, transmit, protect, and eventually dispose of information. Information systems can include networks (computer systems, connections to business partners and the Internet, and the

interconnections between internal and external systems). Other examples are backup tapes, mobile devices, and other media.

Information technology (IT): Any services or equipment, or interconnected system(s) or subsystem(s) of equipment that compose the institution's IT architecture or infrastructure. IT can include computers; ancillary equipment (including imaging peripherals, input, output, and storage devices necessary for security and surveillance); peripheral equipment designed to be controlled by the central processing unit of a computer; software; firmware and similar procedures; services (including cloud computing and help-desk services or other professional services that support any point of the life cycle of the equipment or service); and related resources.

Infrastructure: Describes what has been implemented by IT architecture and often includes support facilities such as power, cooling, ventilation, server and data redundancy and resilience, and telecommunications lines. Specific architecture types may exist for the following: enterprise, data (information), technology, security, and application.

Integrity: Assurance that information is trustworthy and accurate; ensuring that information will not be accidentally or maliciously altered or destroyed (see "Data integrity").

Interconnectivity: The state or quality of being connected together. The interaction of a financial institution's internal and external systems and applications and the entities with which they are linked.

Interdependencies: When two or more departments, processes, functions, or third-party service providers support one another in some fashion.

Internal "trusted" zone: A channel in which the end points are known and data integrity is protected in transit. Depending on the communications protocol used, data privacy may be protected in transit. Examples include SSLIP security and a secure physical connection.

International Organization for Standardization (ISO): An independent, non-governmental, international organization that brings together experts to share knowledge and develop voluntary, consensus-based, market-relevant international standards.

Internet: The global system of interconnected computer networks that use the Internet protocol suite (TCP/IP) to link billions of devices worldwide.

Internet service provider (ISP): A company that provides its customers with access to the Internet (e.g., AT&T, Verizon, and CenturyLink).

Intrusion detection: Techniques that attempt to detect unauthorized entry or access into a computer or network by observation of actions, security logs, or audit data; detection of break-ins or attempts, either manually or via software expert systems that operate on logs or other information available on the network.

Intrusion detection system (IDS): Software or hardware product that detects and logs inappropriate, incorrect, or anomalous activity. It gathers and analyzes information from various areas within a computer or a network to identify possible security breaches, which include both intrusions (attacks from outside the organizations) and misuse (attacks from within the organizations). IDS are typically characterized based on the source of the data they monitor: host or network. A host-based IDS uses system log files and other electronic audit data to identify suspicious activity. A network-based IDS uses a sensor to monitor packets on the network to which it is attached.

Intrusion prevention system (IPS): A system that can detect an intrusive activity and can also attempt to stop the activity, ideally before it reaches its target.

IT system inventory: A list containing information about the information resources owned or operated by an organization.

Life-cycle process: The multistep process that starts with the initiation, analysis, design, and implementation, and continues through the maintenance and disposal of the system.

Log: A record of information or events in an organized system, usually sequenced in the order in which the events occurred.

Logical access: Ability to interact with computer resources granted using identification, authentication, and authorization.

Logical access controls: The policies, procedures, organizational structure, and electronic access controls designed to restrict access to computer software and data files.

Malware: Software designed to secretly access a computer system without the owner's informed consent. The expression is a general term (short for malicious software) used to mean a variety of forms of hostile, intrusive, or annoying software or program code. Malware includes computer viruses, worms, Trojan horses, spyware, dishonest adware, ransomware, crimeware, most rootkits, and other malicious and unwanted software or programs.

Media: Physical objects that store data, such as paper, hard disk drives, tapes, and compact disks.

Metric: A quantitative measurement.

Middleware: Software that connects two or more software components or applications. It is another term for an application programmer interface or API, and it allows programmers to access lower- or higher-level services by providing an intermediary layer that includes function calls to the services.

Mobile device: A portable computing and communications device with information-storage capability. Examples include notebook and laptop computers, cellular telephones and smart phones, tablets, digital cameras, and audio recording devices.

Multi-factor authentication: The process of using two or more factors to achieve authentication. Factors include something you know (e.g., password or personal identification number); something you have (e.g., cryptographic identification device or token); and something you are (e.g., biometric).

National Institute of Standards and Technology (NIST): An agency of the U.S. Department of Commerce that works to develop and apply technology, measurements, and standards. NIST developed a voluntary cybersecurity framework based on existing standards, guidelines, and practices for reducing cyber risks to critical infrastructures.

Network: Two or more computer systems grouped together to share information, software, and hardware.

Network activity baseline: A base for determining typical utilization patterns so that significant deviations can be detected.

Network administrator: The individual responsible for the installation, management, and control of a network.

Network diagram: A description of any kind of locality in terms of its physical layout. In the context of communication networks, a topology describes pictorially the configuration or arrangement of a network, including its nodes and connecting communication lines.

Network security: The protection of computer networks and their services from unauthorized entry, modification, destruction, or disclosure, and provision of assurance that the network performs its critical functions correctly and that there are no harmful side effects. Network security includes providing for data integrity.

Non-public personal information: For purposes of the Information Security Standards, non-public personal information means (i) “personally identifiable financial information”; and (ii) any list, description, or other grouping of consumers (and publicly available information pertaining to them) that is derived using any “personally identifiable financial information” that is not publicly available.

Non-repudiation: Ensuring that a transferred message has been sent and received by the parties claiming to have sent and received the message. Non-repudiation is a way to guarantee that the sender of a message cannot later deny having sent the message and that the recipient cannot deny having received the message.

Operating system: A system that supports and manages software applications. Operating systems allocate system resources, provide access and security controls, maintain file systems, and manage communications between end users and hardware devices.

Out-of-band: Activity outside of the primary means of interfacing with the customer. For example, if a user is performing activity online, he or she may be authenticated through a one-time password sent via text message.

Outsourcing: The practice of contracting with another entity to perform services that might otherwise be conducted in-house; a contractual relationship with a third party to provide services, systems, or support.

Packet: The data unit that is routed from source to destination in a packet-switched network.

Patch: Software code that replaces or updates other code. Patches frequently are used to correct security flaws.

Penetration test: The process of using approved, qualified personnel to conduct real-world attacks against a system to identify and correct security weaknesses before they are discovered and exploited by others.

Personally identifiable financial information: For purposes of the Information Security Standards, personally identifiable financial information means information (i) a consumer provides to a financial institution to obtain a financial product or service; (ii) about a consumer resulting from any transaction involving a financial product or service between the financial institution and a consumer; or (iii) that a financial institution otherwise obtains about a consumer in connection with providing a financial product or service, such as account balance information, payment history, overdraft history, and credit or debit card purchase information; or the fact that an individual is one of the financial institution's customers.

Phishing: A digital form of social engineering that uses authentic-looking—but bogus—e-mail to request information from users or direct them to fake websites that request information.

Policy: A document that records a high-level principle or an agreed-upon course of action; overall intention and direction as formally expressed by management.

Port: Either an end point to a logical connection or a physical connection to a computer.

Positive pay: A technique that can reduce check fraud by requesting businesses to send electronic files of information to the financial institution on all checks the business has issued.

Preventive control: A mitigating technique designed to prevent an event from occurring.

Principle of least privilege: The security objective of granting users only the access needed to perform official duties.

Privilege: The level of trust with which a system object is imbued.

Privileged access: Individuals with the ability to override system or application controls.

Protocol: A format for transmitting data between devices.

Real-time network monitoring: Immediate response to a penetration attempt that is detected and diagnosed in time to prevent access.

Remote access: The ability to obtain access to a computer or network from a remote location.

Remote deletions: Use of a technology to remove data from a portable device without touching the device.

Removable media: Portable electronic storage media, such as magnetic, optical, and solid-state devices that can be inserted into and removed from a computing device and that are used to store text, video, audio, and image information. Such devices have no independent processing capabilities. Examples include hard disks, floppy disks, zip drives, compact disks, thumb drives, pen drives, and similar storage devices.

Resource: Any enterprise asset that can help the organization achieve its objectives.

Retention requirement: Requirement established by a company or by regulation for the length of time and/or for the amount of information that should be retained.

Risk analysis: The process of identifying risks, determining their probability and impact, and identifying areas needing safeguards.

Risk assessment: A prioritization of potential business disruptions based on severity and likelihood of occurrence. The risk assessment includes an analysis of threats based on the impact to the institution, its customers, and financial markets, rather than the nature of the threat.

Rogue wireless access: An unauthorized wireless node on a network.

Routing: The process of moving information from its source to the destination.

Sandbox: A restricted, controlled execution environment that prevents potentially malicious software, such as mobile code, from accessing any system resources except those for which the software is authorized.

Scenario analysis: The process of analyzing possible future events by considering alternative possible outcomes.

Secure shell: Network protocol that uses cryptography to secure communication, remote command line log-in, and remote command execution between two networked computers.

Secure Sockets Layer (SSL): A protocol that is used to transmit private documents through the Internet.

Security architecture: A detailed description of all aspects of the system that relate to security, along with a set of principles to guide the design. A security architecture describes how the system is put together to satisfy the security requirements.

Security audit: An independent review and examination of system records and activities to test for adequacy of system controls, ensure compliance with established policy and operational procedures, and recommend any indicated changes in control, policy, and procedures.

Security breach: A security event that results in unauthorized access of data, applications, services, networks, or devices by bypassing underlying security mechanisms.

Security event: An event that potentially compromises the confidentiality, integrity, availability, or accountability of an information system.

Security log: A record that contains log-in and logout activity and other security-related events and that is used to track security-related information on a computer system.

Security posture: The security status of an enterprise's networks, information, and systems based on information security and assurance resources (e.g., people, hardware, software, and policies) and capabilities in place to manage the defense of the enterprise and to react as the situation changes.

Security violation: An instance in which a user or other person circumvents or defeats the controls of a system to obtain unauthorized access to information or system resources.

Sensitive customer information: A customer's name, address, or telephone number, in conjunction with the customer's social security number, driver's license number, account number, credit or debit card number, or personal identification number or password that would permit access to the customer's account. Sensitive customer information also includes any combination of components of customer information that would allow someone to log into or access the customer's account, such as user name and password or password and account number.

Server: A computer or other device that manages a network service. An example is a print server, which is a device that manages network printing.

Service level agreement (SLA): Formal documents between an institution and its third-party service provider that outline an institution's predetermined requirements for a service and establish incentives to meet, or penalties for failure to meet, the requirements. SLAs should specify and clarify performance expectations, establish accountability, and detail remedies or consequences if performance or service quality standards are not met.

Service provider: For purposes of the Information Security Standards, service provider means any person or entity that maintains, processes, or otherwise is permitted access to customer information or consumer information through its provision of services directly to a financial institution.

Shadow IT: A term used to describe IT systems or applications used inside institutions without explicit approval.

Sniffing: The passive interception of data transmissions.

Social engineering: A general term for trying to trick people into revealing confidential information or performing certain actions.

Spear phishing: An attack targeting a specific user or group of users, and attempts to deceive the user into performing an action that launches an attack, such as opening a document or clicking a link. Spear phishers rely on knowing some personal piece of information about their target, such as an event, interest, travel plans, or current issues. Sometimes this information is gathered by hacking into the targeted network.

Spoofing: A form of masquerading in which a trusted IP address is used instead of the true IP address as a means of gaining access to a computer system.

SQL Injection Attack: An exploit of target software that constructs structured query language (SQL) statements based on user input. An attacker crafts input strings so that when the target software constructs SQL statements based on the input, the resulting SQL statement performs actions other than those the application intended. SQL injection enables an attacker to talk directly to the database, thus bypassing the application completely. Successful injection can cause information disclosure as well as the ability to add or modify data in the database.

Stateful inspection: A firewall inspection technique that examines the claimed purpose of a communication for validity. For example, a communication claiming to respond to a request is compared to a table of outstanding requests.

System administration: The process of maintaining, configuring, and operating computer systems.

System resources: Capabilities that can be accessed by a user or program either on the user's machine or across the network. Capabilities can be services, such as file or print services, or devices, such as routers.

Third-party relationship: Any business arrangement between a financial institution and another entity, by contract or otherwise.

Third-party service provider: Any third party to whom a financial institution outsources activities that the institution itself is authorized to perform, including a technology service provider.

Threat intelligence: The acquisition and analysis of information to identify, track, and predict cyber capabilities, intentions, and activities that offer courses of action to enhance decision making.

Trojan horse: Malicious code hidden in software that has an apparently beneficial or harmless use.